

Governance Centre

Full walkthrough, all sixteen sections

Product	Attest AI Platform
Worked example	Northgate Legal
Follow along at	<code>/portal/demo.html</code>
Date	11 Aug 2026
Sections	12 governance + 4 manage

Follow along with no account. Open `/portal/demo.html`. It runs the real Governance Centre against sample data held in `sessionStorage`, seeded as Northgate Legal, the same firm used throughout this document. Nothing you type there reaches the database, and closing the tab resets it.

Field names and dropdown options in this document are taken from the shipped code, not from a design.
Where a section's behaviour is not yet functional, the step says so rather than pretending. See section 18.

1. Before you start

The order matters

The registers reference each other. Build them in this order and nothing ever asks you to pick a record that does not exist yet:

#	Section	Why it comes here
1	Staff & Sign-off	Owner pickers on every other register read from staff records. Add people first and every later dropdown is populated.
2	Vendor Due Diligence	The AI Tool Register's supplier field points at vendors.
3	Vendor Risk Score	Scores the diligence answers once they come back.
4	AI Tool Register	Use cases point at tools, and Section 3 of the policy is generated from this register.
5	Use Case Register	Risks and assessments both reference use cases.
6	Risk Assessments	Sets the use case's risk rating automatically.
7	AI Risk Register	Optionally links to a use case.
8	Acceptable Use Policy	Generated from the registers. Do it last or Section 3 is thin.
9	Incidents, RACI, ToR	Independent, do them whenever.

Northgate Legal, the worked example

A 42-person law firm. Two partners, a practice manager, a small IT contractor. They have Copilot on business licences, several people using personal ChatGPT accounts, and a contract-review tool a partner signed up for without telling anyone. That last one is the reason the AI Tool Register exists.

One habit worth forming. The Governance Centre list is generated from your registers, never typed. An item disappears when the underlying record is fixed. So work top down, fix the record, and check back rather than trying to clear the list directly.

2. Staff & Sign-off, do this first

Nav: **Staff & Sign-off**. Populates the owner picker on every other register.

Add your first person

#	Do this	Northgate Legal example
1	Click + Add staff member	Top right of the page
2	Name	Priya Raman
3	Email	p.raman@northgatelegal.co.uk
4	Role / department	Practice Manager
5	Save	She now appears in every owner dropdown

Repeat for the people who will own things. For Northgate, add at least:

Name	Email	Role / department
Priya Raman	p.raman@northgatelegal.co.uk	Practice Manager
David Okonjo	d.okonjo@northgatelegal.co.uk	Partner, Commercial
Sarah Whitfield	s.whitfield@northgatelegal.co.uk	Partner, Litigation
Tom Bewley	tom@bewleyIT.co.uk	IT (contractor)

Announce the policy, once it is published

#	Do this	What happens
6	Click Copy announcement message	Clipboard gets the policy version, the company name, your DPO and incident contact, and the absolute portal sign-in URL. Paste it into email, Slack or Teams.
7	Click Email reminder on one person's row	Opens your mail client, addressed to them, with the policy version and the sign-in link in the body.
8	Read the Policy ack column	<i>Acknowledged</i> with a date, or <i>Not yet</i> . Acknowledgements are tied to a policy version, so publishing a new version resets everyone to outstanding.

Known limitation. This roster reads acknowledgements from one store, and the staff portal writes them to another. They are not linked yet, so a sign-off made by a member of staff may not appear in this column. Decision pending, see section 18.

3. Vendor Due Diligence

Nav: **Vendor Due Diligence**. Step 1 of vendor onboarding. Send it before you buy.

#	Field	Northgate Legal example
1	Click + Add vendor	
2	Vendor name	Lexvia Ltd
3	Product / tool	Lexvia Contract Review, Professional tier
4	Vendor contact (name / email)	Ana Bright / ana.bright@lexvia.example
5	Diligence checklist	Tick each question as the supplier answers it. There are 23 must-answer questions.
6	Notes	Answers received 14 Aug. Sub-processor list incomplete, chased.

What the 23 questions cover

Legal entity and group structure; the tool and tier; underlying foundation models; countries of processing and storage; an EU-only processing option; retention of prompts, responses, metadata and embeddings; a contractual commitment that your data is not used for training; deletion on request including backups and sub-processors; the full sub-processor list and change notification; a DPA with SCCs; EU AI Act Article 26 deployer-facing instructions; a current ISO 27001 certificate and Statement of Applicability; SSO, SCIM, MFA and RBAC; per-model provider, version and limitations; whether any model is high-risk under Annex III; cross-tenant isolation controls; a contractual 72-hour breach notification SLA; the Article 73 serious-incident process; advance notice of material changes; and four Cyber Resilience Act questions covering scope, the Article 14 disclosure contact, declaration of conformity and CE marking, and an SBOM with the declared security-update support period.

Why ask a SaaS vendor about the CRA. Pure software as a service is usually outside CRA scope. The answer still tells you which kind of supplier you are dealing with, and a vendor who cannot answer it is telling you something.

4. Vendor Risk Score

Nav: **Vendor Risk Score**. Step 2. Score the answers and record a decision.

#	Field	Northgate Legal example
1	Click + Score a vendor	
2	Vendor / product	Pick Lexvia Ltd from the list
3	What we use it for	First-pass review of commercial contracts before a partner reads them
4	Data shared with them	Client contract text, counterparty names. No special-category data.
5	Their AI Act role	Provider
6	Assessed by / date	Priya Raman / 18 Aug 2026
7	Score each area (1 low – 5 high)	Score from the diligence answers, not from impressions
8	Decision	Approved with conditions
9	Decided by	David Okonjo
10	Re-assess by	18 Aug 2027
11	Conditions to clear	Full sub-processor list before go-live. EU-only processing enabled.

Approving here is what lets the tool become a use case later. A vendor with no score is a flag on the Governance Centre.

5. AI Tool Register

Nav: **AI Tool Register**. Every AI tool people can reach, including the ones you never bought.

The field that does the work

Account type is the point of this register. The same product on a business licence and on someone's personal login are two different answers, so they are two rows. Record them separately or the policy will tell staff the wrong thing.

#	Field	Example: the approved one
1	Status	Approved (Awaiting assessment · Approved · Approved with conditions · Restricted · Not approved)
2	Tool name	Microsoft 365 Copilot
3	Account type	Enterprise / business account (Enterprise / business · Team · Personal / consumer · Unknown)
4	Supplier (if we have a contract)	Microsoft
5	Most sensitive data permitted	Confidential business (None — do not use with company data · Public · Internal non-sensitive · Confidential business · Personal data (general) · Special-category)
6	Conditions or restrictions	No client-identifying matter detail. Never for advice that goes out unreviewed.
7	Decision owner	Priya Raman
8	Review by	01 Jun 2027

Now add the same product on a personal account

Field	Example: the shadow one
Status	Restricted
Tool name	ChatGPT
Account type	Personal / consumer account
Supplier	Leave empty. There is no contract, which is exactly why it belongs here.
Most sensitive data permitted	None — do not use with company data
Conditions or restrictions	Public information only. Nothing from a matter file, ever.
Decision owner	Priya Raman
Review by	01 Dec 2026

A tool with no supplier still belongs here. A personal ChatGPT account has nobody to send diligence to, so it can never arrive through Vendor Due Diligence. This register is the only place it will ever be recorded.

6. Use Case Register

Nav: **Use Case Register**. What each tool is actually used for.

#	Field	Northgate Legal example
1	Use case name	First-pass commercial contract review
2	Purpose (one sentence)	Summarise and flag unusual clauses in inbound commercial contracts before a partner reads them.
3	AI tool used	Pick Lexvia Contract Review from the tool list
4	Input data categories	Confidential business (Public · Internal non-sensitive · Confidential business · Personal data (general) · Special-category)
5	Use case owner	David Okonjo
6	DPIA required	Yes (Yes · No · Pending)
7	FRIA required	No (Yes · No · Pending)
8	Risk rating	Leave it. The risk assessment sets this and keeps it in step.
9	Status	Active (Active · Paused · Discontinued)
10	Notes	Partner review is mandatory before anything leaves the firm.

Deliberate trap. Name a tool here that is not in the AI Tool Register and the Governance Centre raises a flag naming it. That is the feature, not a bug: it is how shadow AI surfaces.

7. Risk Assessments

Nav: **Risk Assessments**. Sets the use case's risk rating automatically.

#	Field	Northgate Legal example
1	Use case / tool	Pick First-pass commercial contract review
2	Owner (name / role)	David Okonjo / Partner, Commercial
3	Assessment date	20 Aug 2026
4	Data involved	Contract text, counterparty names, commercial terms. No special-category data.
5	Who is affected	Clients, counterparties, and the fee earners relying on the summary.
6	EU AI Act risk tier	Limited risk
7	Score the risks, Likelihood × Impact (1–5 each)	Five rows: wrong or made-up output used as fact; confidential or personal data exposed to the tool; bias or unfair outcome; no human check before acting; vendor, supply-chain or availability failure.
8	Decision	Approved with conditions
9	Decided by	Sarah Whitfield
10	Review date	20 Aug 2027
11	Conditions (if any)	Partner sign-off before any output is sent to a client. Quarterly sample check of ten reviews.

Save, then reopen the use case. Its **Risk rating** now reflects this assessment, and stays in step if you change the scores.

8. AI Risk Register

Nav: AI Risk Register. Risks that outlive any single use case.

#	Field	Northgate Legal example
1	Status	Open (Open · In progress · Complete · Deferred)
2	Risk category	Shadow AI (Data leakage · Hallucination · Bias · Vendor risk · Compliance gap · Shadow AI · Operational)
3	Related use case (optional)	Leave empty, this one is firm-wide
4	Risk description (be specific)	Fee earners pasting matter detail into personal ChatGPT accounts we do not control or monitor.
5	Current controls	AUP published. Induction covers it. No technical block in place.
6	Likelihood	High (Very low · Low · Medium · High)
7	Impact	Critical (Low · Medium · High · Critical)
8	Risk owner	Priya Raman
9	Mitigation action	Provide Copilot licences to all fee earners, then block consumer AI domains on the firm network.
10	Mitigation due date	31 Oct 2026
11	Residual scores	Leave blank until the mitigation is planned and real.

Residual risk reads "Not scored" until you score it. It does not quietly inherit the inherent score. An auditor can tell the difference between a residual risk you assessed and one the software assumed.

9. Acceptable Use Policy

Nav: **Acceptable Use Policy**. Do this after the registers, not before.

#	Field	Northgate Legal example
1	Company name	Northgate Legal LLP
2	Effective date	01 Sep 2026
3	Policy owner (role)	Practice Manager
4	DPO / contact name	Priya Raman
5	Fill the remaining numbered fields	Each one fills the section of the policy it names.
6	Read Section 3 in the preview	It is generated from your AI Tool Register, with each tool's account type and permitted data. Both Copilot rows and the restricted ChatGPT row should appear.
7	Save	Increments the draft version. Nothing is live yet.
8	Publish	Makes it live, stamps the date, and asks every member of staff to acknowledge it again.

Test it properly. Empty the Tool Register and regenerate: Section 3 falls back to a typed list rather than producing an empty section. Then refill it and regenerate. That round trip is the difference between a generated policy and a template.

10. Incident Reports

Nav: **Incident Reports**. Fill it in on the worst day, so write it now.

#	Field	Northgate Legal example
1	Reporter (name + role)	Tom Bewley, IT contractor
2	Discovered	03 Sep 2026
3	Status	Open
4	Type	Data exposure
5	Severity	High
6	Personal data involved	Yes
7	AI tool + version/tenant	ChatGPT, personal account, free tier
8	Channel	Reported by the fee earner to the Practice Manager
9	Factual summary	A paralegal pasted two paragraphs of a witness statement, including the witness's name and address, into a personal ChatGPT account to shorten it. Facts only, no speculation.
10	Detection (how / by whom)	Self-reported the same afternoon after the AUP induction.
11	Containment actions taken	Chat deleted, account history disabled, matter partner informed, client not yet notified pending assessment.
12	Root cause	No Copilot licence for paralegals, so the approved route did not exist for them.
13	Lessons and changes required	Extend Copilot licences to paralegals. Raise risk R-002 to In progress.
14	Closed date	Leave empty until it genuinely is

The 72-hour GDPR clock starts at awareness, not at closure. Record **Discovered** accurately even when it is inconvenient.

11. Roles Matrix (RACI) and 12. Steering Group ToR

RACI

Nav: **Roles Matrix (RACI)**. Who is Responsible, Accountable, Consulted, Informed.

Activity	Northgate Legal example
Approving a new AI tool	R: Priya Raman · A: David Okonjo · C: Tom Bewley · I: All staff
Publishing the AUP	R: Priya Raman · A: Sarah Whitfield · C: David Okonjo · I: All staff
Handling an AI incident	R: Tom Bewley · A: Priya Raman · C: matter partner · I: Steering group
Annual refresher training	R: Priya Raman · A: Priya Raman · C: none · I: All staff

One Accountable per row. If two people are accountable, nobody is.

Steering Group ToR

Nav: **Steering Group ToR**. Complete, save, export.

Field	Northgate Legal example
Purpose	Oversee safe and lawful AI adoption across the firm.
Membership	Managing Partner (chair), Practice Manager, one fee-earning partner, IT contractor.
Frequency	Quarterly, and within five working days of any High or Critical incident.
Standing agenda	New tool requests, open risks, incidents since last meeting, training completion, policy version.
Decision rights	Approve or restrict tools. Accept residual risk up to High. Critical goes to the full partnership.

13. Governance Centre, reading the flags

Nav: **Governance Centre**. Generated from your registers, never typed.

Deliberately trigger each flag

The fastest way to trust the list is to make it fire, then clear it.

#	Do this	Flag it raises, and how to clear it
1	Add a use case naming a tool not in the register	Raises a flag naming the unregistered tool. Clear it by adding the tool.
2	Set a tool to Restricted , then build a use case on it	Raises a restricted-tool flag. Clear it by approving the tool or discontinuing the use case.
3	Leave a tool at Awaiting assessment	Raises an awaiting-decision flag. Clear it by deciding.
4	Set a tool's Review by to yesterday	Raises a past-review flag. Clear it by reviewing and moving the date.
5	Set a tool to Approved with no Decision owner	Raises an unowned-approval flag. Clear it by naming an owner.

Objectives

#	Do this	Northgate Legal example
6	Click + Add objective	Every fee earner trained and signed off by 31 Oct 2026
7	Set a target date in the past	Flagged overdue immediately
8	Change it to a future date	The flag clears with no stored field changing. Overdue is computed, never saved.

What you will not find here, on purpose. There is no "N users are using unapproved AI" figure. The platform cannot see your network, so it does not pretend to. Every number on this page traces to a record you entered.

14 to 17. The Manage group

Nav: [Team](#), [Course](#), [Templates](#), [Updates](#).

14. Team

#	Do this	What happens
1	Check your credit balance	One credit per seat. Bought with your plan.
2	Invite a colleague by email	Spends one credit, creates the account, seats them under you, emails them a link.
3	Try inviting the same person twice	Refused as already seated, and it does not spend a second credit.
4	Try inviting someone another firm manages	Refused. Nobody is silently moved between organisations.
5	Try inviting at zero balance	Refused with no credits remaining. The balance never goes negative.

Not functional yet. Invitations need custom SMTP, which is not configured. The credit accounting is correct; the email does not arrive. See section 18.

15. Course

Do this	What happens
Read the completion table	Modules completed per seated person. You see only your own people.
Export the completion CSV	Downloads, opens in a spreadsheet, contains only your seated users.

Not trustworthy yet. Quiz results are held in the learner's own browser and never reach the database, so this table and the CSV have no server-side source. Do not hand the export to an auditor until that is fixed. See section 18.

16. Templates

27 fill-in governance documents. Open any one, complete it offline, keep it with your audit pack. They complement the generated policy rather than replacing it.

17. Updates

The product changelog. Worth a glance each quarter, because a content update usually means a regulation moved. The Digital Omnibus on AI, in force 27 July 2026, is the current example: it deferred the EU AI Act's high-risk regime to December 2027 and August 2028, and softened the Article 4 literacy duty to an obligation of effort.

18. Honest limits at the time of writing

Everything above is walkable today except where marked. These four are real and known.

Limit	Effect on this walkthrough
No custom SMTP	Section 14 invitations do not arrive. Credits are spent and the account is created correctly; nobody is emailed.
Quiz results are local only	Section 15 completion tracking has no server-side source. Clearing a browser erases a learner's record.
Two acknowledgement stores	Section 2's Policy ack column may not show a sign-off made in the staff portal. Which store is authoritative is undecided.
Staff cannot open the sign-off page	The acknowledgement panel sits on a manager-only page, so staff are bounced. Inherited from the artifact this screen was ported from.

Using this as a test script. Follow sections 2 to 13 in order against `/portal/demo.html`. Every step has one observable outcome, so a step that does not produce it is a defect. Sections 14 and 15 will fail for the reasons above; record those as blocked, not failed.

Using this as the guided-tour script. Each numbered row is one tour step: a target section, an instruction, and an expected result. The order in section 1 is the tour order, because it is the only sequence in which no step references a record that does not exist yet.